

SBSEG 2026 · BÚZIOS, RJ · 1 A 4 DE SETEMBRO



CryptoCensus

Postura criptográfica e prontidão
pós-quântica do Docker Hub



Cristhian Kapelinski · Diego Kreutz
AI Horizon Labs · UNIPAMPA
WTICG · trabalho completo



AI HORIZON
LABS
Explorando Novas Fronteiras da Inteligência Artificial



A ameaça quântica

- Colher agora, decifrar depois
- Shor quebra RSA e curvas elípticas
- Dado com sigilo longo já está exposto

Cronograma do NIST

No nível de 112 bits de segurança

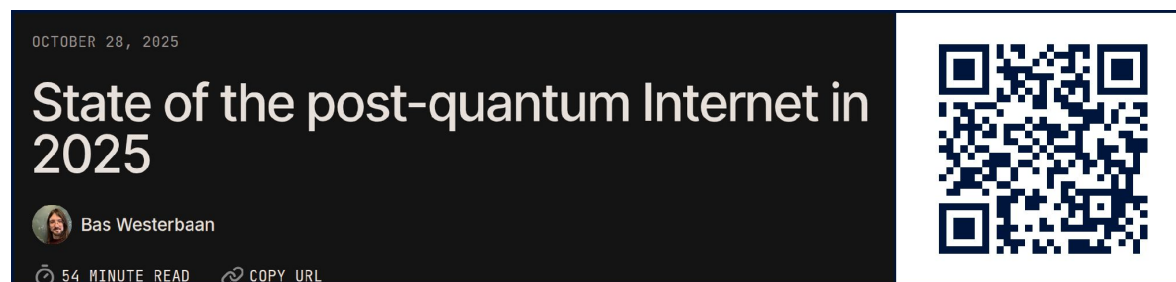
- **2030** depreciar RSA e curvas elípticas
- **2035** proibir RSA e curvas elípticas

PUBLICATIONS NIST IR 8547 (Initial Public Draft)  Transition to Post-Quantum Cryptography Standards     Date Published: November 12, 2024 Comments Due: January 10, 2025 (public comment period is CLOSED)	
--	---

Tráfego humano na Cloudflare, 2025

mais da metade

com troca de chaves híbrida

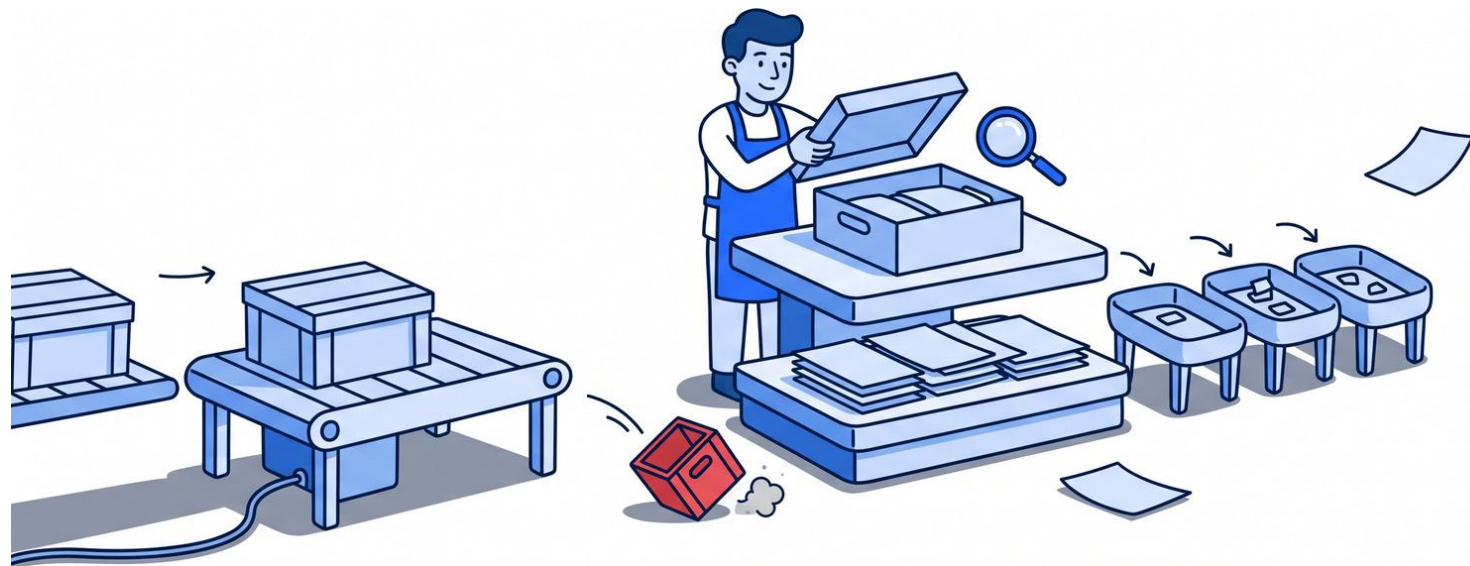


Os três trabalhos mais próximos

Trabalho	Inventário	Pós-quântico	Sorteio
Dahlmanns, 2023 337.171 imagens	●	○	○
Strauss, 2025 4.018 apps Android	●	●	○
CryptoCensus ESTE TRABALHO 11.962 imagens	●	●	●

01

Censo



0 sorteio, com chance igual

- **12.716.568** repositórios enumerados
- **20.000** sorteados
- **11.962** imagens analisadas

Nas 11.962 imagens,

4.211.380

certificados e chaves

O que o extrator lê

- **Certificados e chaves**
- **Tokens legados de TLS e SSH**
- **Bibliotecas em dpkg e apk**

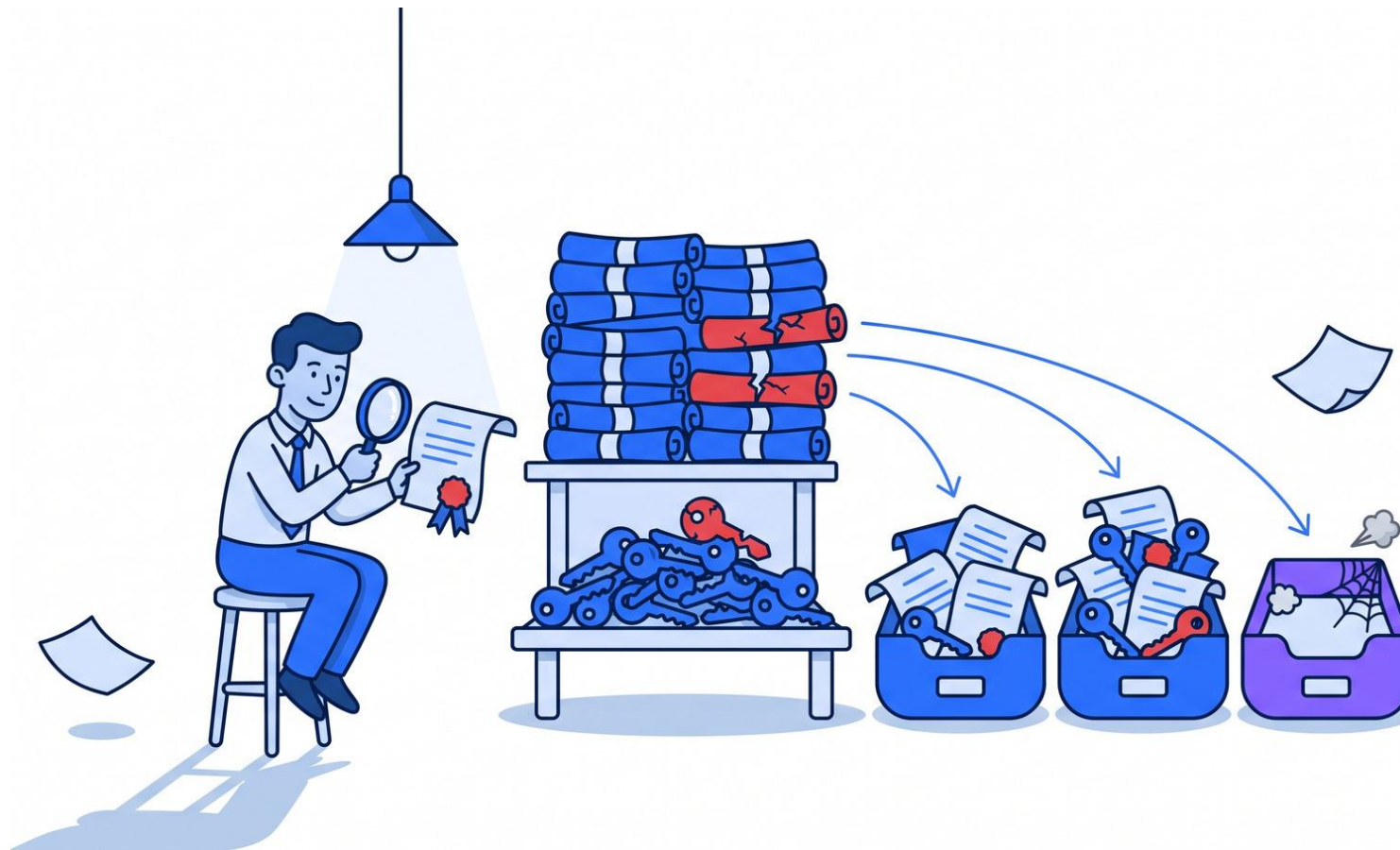
Trust store, e o que está fora dele

- **3.514.257** no trust store da distribuição
- **697.123** trazidos pela própria imagem

Daqui em diante: fora do trust store.

02

Os achados



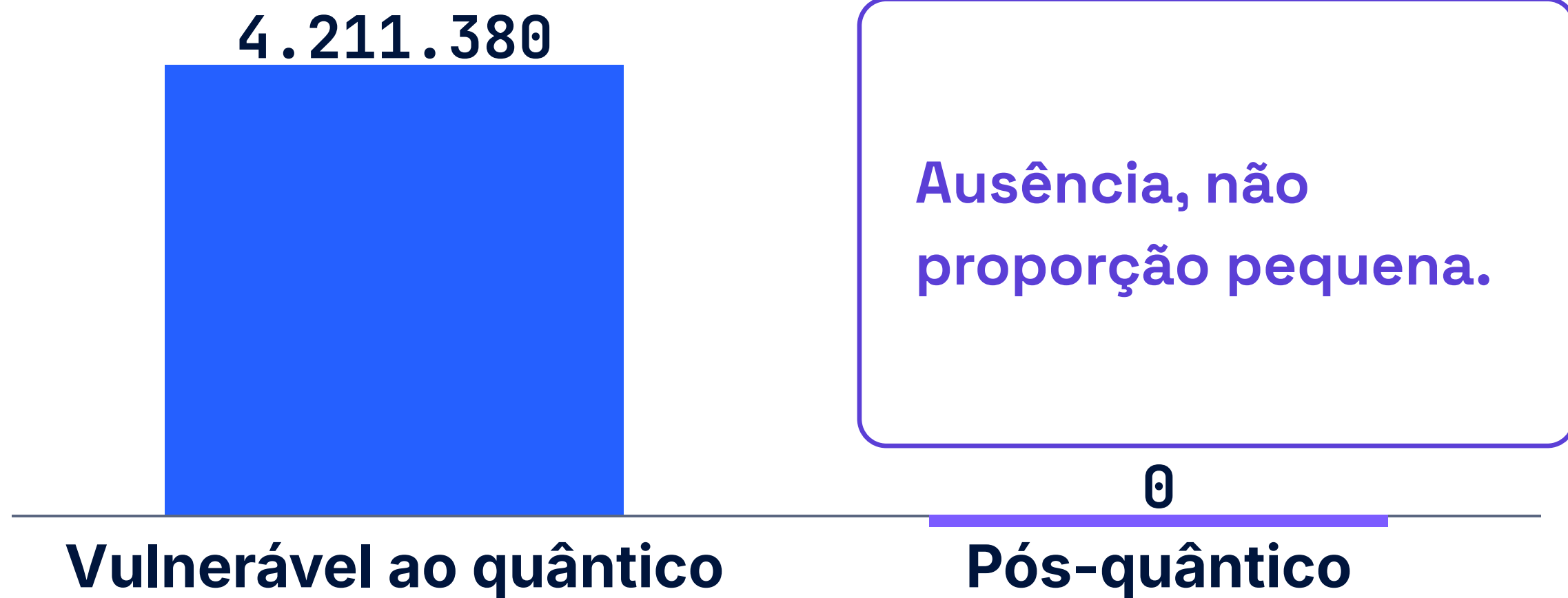
O que as 20.000 referências devolveram

- **34,7%** sem publicar latest
- **5,4%** fora do escopo
- **59,9%** baixadas e analisadas

O que ficou fora do escopo

- **657** passam de 4 GiB extraídos
- **192** são privadas
- **148** não têm variante amd64

Prontidão pós-quântica



Todas as famílias são clássicas

- **RSA, Diffie-Hellman, DSA, ECDSA e EdDSA**
- **Nenhum ML-KEM, ML-DSA ou SLH-DSA**

Das 11.962 imagens sorteadas,

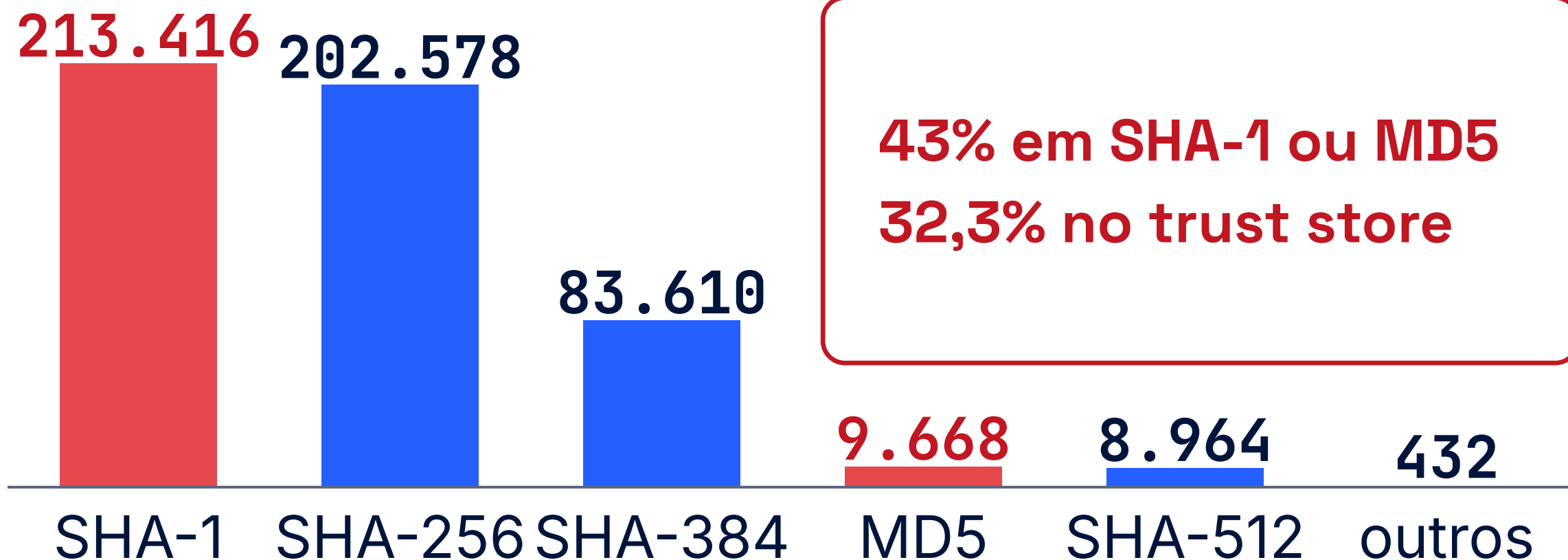
801

**imagens já trazem OpenSSL 3.5 ou liboqs
instalada**

6,7% do total, IC 95% de 6,3 a 7,2%

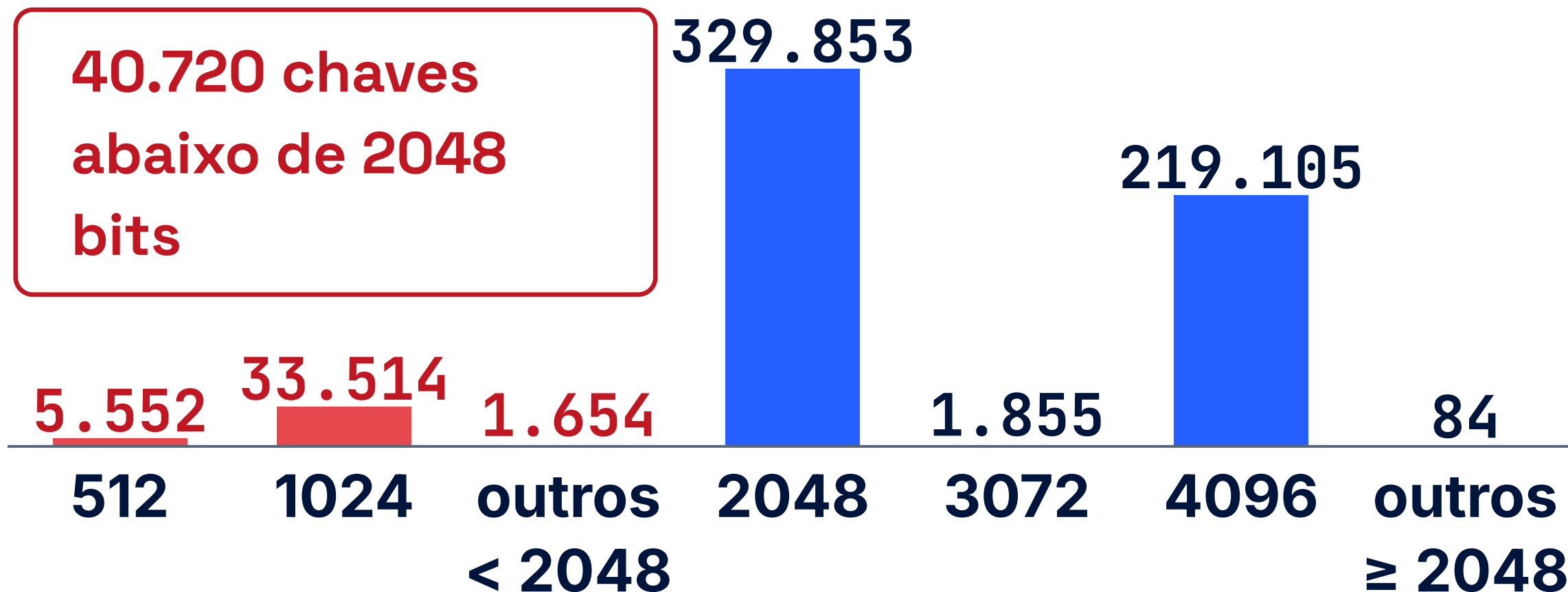
Hash da assinatura

Nos 518.668 certificados fora do trust store.



Tamanho das chaves RSA

Das 697.123 fora do trust store, 591.617 são RSA.



Chaves RSA de 512 bits

Não é fraco na teoria: está quebrado na prática.

5.552

das 591.617 chaves RSA fora do trust store

75 dólares de nuvem, com ferramenta pública

Tokens legados na configuração

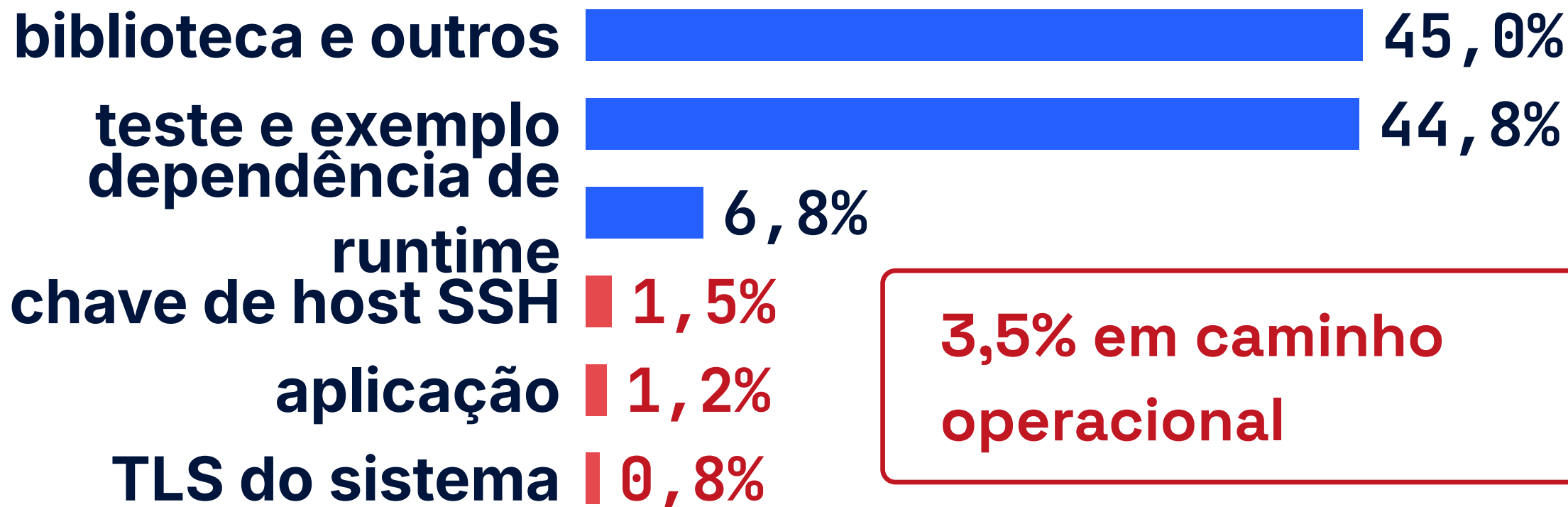
Ocorrências em configuração de TLS e SSH.



Presença estática não
prova opção ligada.

Onde estão as chaves privadas

Nas 37.077 chaves privadas e de host SSH.



Reuso de chave entre imagens

7.141 Fora do trust store
fingerprints distintos

2.412 Repetem em outra imagem
por herança de imagem base

36 Só em caminho operacional
chaves privadas que se repetem

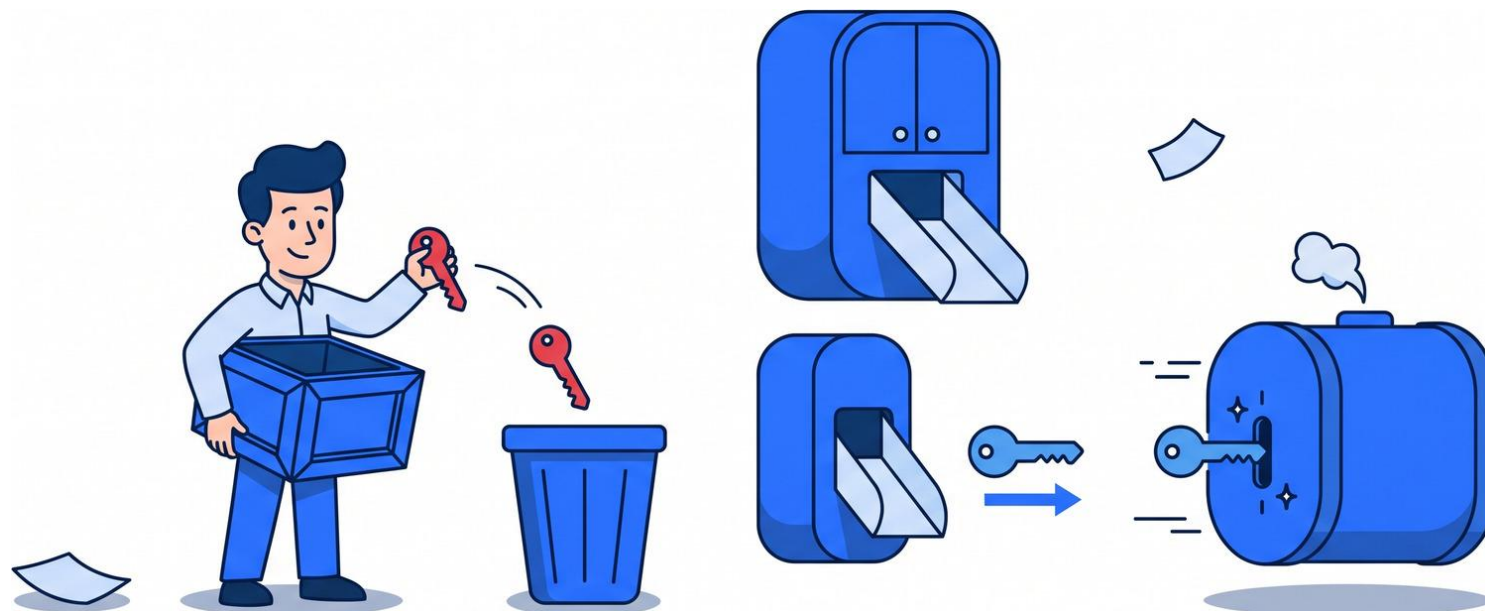
As duas mais repetidas assinam pacote do Alpine.

Limitações

- **Só arquivo estático, só linux/amd64**
- **Biblioteca só por dpkg e apk: 801 é limite inferior**
- **Uma medição única: nível, não tendência**

03

Conclusões



Recomendações

- **Chave gerada na implantação, não na imagem**
- **Build rejeita RSA < 2048 e SHA-1 ou MD5**

Migração pós-quântica

Ter a biblioteca instalada não é ter migrado.

- **Configurar o protocolo para negociar pós-quântico**
- **Provisionar chave ou certificado pós-quântico**
- **Testar a negociação em execução**

As 801 pararam no primeiro passo.

Contribuição

- **Censo atual da postura criptográfica do Docker Hub**
- **Nenhum pós-quântico, nem nas 801 com biblioteca**
- **Pipeline e dados abertos**

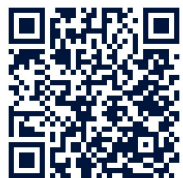


Obrigado!

Perguntas são bem-vindas

Cristhian Kapelinski

cristhianavila.aluno@unipampa.edu.br



Artefato Laboratório Artigo

Apoio



FAPERGS

Fundação de Amparo à Pesquisa do Estado do Rio Grande do Sul



Primo compartilhado entre módulos

Compara todo par de módulos RSA de uma vez.

Fora do trust store, o
corpo do teste tem

6.116

módulos RSA distintos

Compartilham um primo e
são recuperáveis

4

módulos, ou 0,065%

Um primo comum recupera os dois módulos.

Como a taxa se compara

0,50% dos hosts TLS da Internet (Heninger, 2012)

0,065% dos módulos deste censo

0,00056% das chaves SSH de desenvolvedores (Baumer 2025)

Só esse modo de falha, e só neste corpo.

Chave de baixa entropia fica de fora.

Comparação com o que já se mediu

Estudo	População	Resultado
Hash da assinatura		
Holz, 2011	Certificados da Web	17,3% em MD5
Este trabalho	Certificados de imagem	43% MD5 ou SHA-1
Primo compartilhado		
Heninger, 2012	Hosts TLS da Internet	0,50% dos hosts
Baumer, 2025	Chaves SSH de devs	0,00056% das
Este trabalho	Módulos RSA de imagem	0,065% dos módulos

Comparação com o que já se mediu

Estudo	População	Resultado
Chave privada		
Dahlmanns,	337.171 imagens	52.107 chaves
Este trabalho	11.962 imagens	36 chaves
		repetidas
Uso pós-quântico		
Strauss, 2025	Apps Android em	Nenhum
Este trabalho	Chaves e	Nenhum
Contexto, não replicação.		

A forma do material extraído

Dos 518.668 certificados fora do trust store.

autoassinado  95,6%

marcado como CA  92,9%

expirado  20,2%

Autoassinado e CA se sobrepõem em 88%.
É a forma de uma raiz privada.

O que essa forma quer dizer

- A maior parte tem forma de raiz privada, não de certificado de servidor vazado
- Autoassinar não é fraqueza por si
- Certificado expirado e em uso faz o verificador de data rejeitar a conexão

Um em cada cinco certificados está expirado.

Divergência entre detectores

Onde o detector
achou certificado

9.888

imagens

O CBOM-Lens
relata, na
mediana,

50%

do que o detector

Das 9.888
imagens, o
CBOM-Lens

18%

igual ou supera

O detector interno dá as contagens.

O CBOM-Lens segue o padrão CycloneDX.

O que a divergência mostra

- A cobertura dos dois detectores é diferente
- A taxa de erro fica em aberto: não há verdade de referência
- O Gitleaks entra como terceiro detector, só na auditoria de caminho

Nenhum externo entra nas contagens.

Por que a tag latest, se 34,7% não resolvem?

O crawl enumera repositório, não a lista de tags: latest é a única referência que existe para todos, e é a tag padrão do registro. Sete semanas depois, 193 de 200 referências não resolvidas continuavam no ar, nenhuma com latest, e a mediana do último envio delas é 2022. A estimativa vale para quem publica latest.

O sorteio é equiprovável do registro inteiro?

Do quadro amostral: os 12.716.568 repositórios do crawl do ChimangoScan. Dentro dele, cada repositório tem exatamente a mesma chance. A ordem sai do SHA-256 de cryptocensus:referência, e entram os 20.000 primeiros. Não afirmo nada sobre repositório que não está no crawl.

E a criptografia negociada em execução?

Fica fora. O censo lê arquivo estático de imagem linux/amd64, não o que é gerado, buscado ou negociado quando o contêiner roda. Observação em execução pode revelar uso pós-quântico que este censo não vê. Está declarado nas limitações do artigo.

E biblioteca ligada estaticamente?

A detecção de biblioteca lê só dpkg e apk, então as 801 são limite inferior. Mas o zero não é de biblioteca, é de chave e certificado: nenhum dos 4.211.380 objetos extraídos é pós-quântico. Biblioteca ligada estaticamente não deixa chave pós-quântica no sistema de arquivos.

O corte do trust store é arbitrário?

Os caminhos estão documentados no artefato: /etc/ssl/certs, /etc/pki, os pacotes de CA da distribuição e o certifi do Python. Sem o corte, um pacote de CA repetido em milhares de imagens afoga a análise de postura, de reuso e de primo compartilhado. A análise inteira roda de novo com outro corte.

Zero pós-quântico não é cedo demais?

A ferramenta já existe. O NIST padronizou em 2024, a OpenSSL 3.5 traz ML-KEM, ML-DSA e SLH-DSA de fábrica, e 801 imagens já a têm instalada. No transporte, mais da metade do tráfego humano da Cloudflare já negocia híbrido. O que falta não é ferramenta, é uso.

43% em SHA-1 ou MD5 é grave, se é quase tudo raiz privada?

96% são autoassinados e 93% vêm marcados como autoridade: a forma é de raiz privada, não de certificado de servidor vazado. Isso muda o risco de vazamento para gestão. Mas raiz privada assinada com SHA-1 continua fraca, e 20% do material já venceu.

As 36 chaves repetidas são exploráveis?

Não testei, e por escolha. As imagens são lidas como dado estático, nunca executadas, e nenhuma chave foi testada contra sistema vivo. O que a medição afirma é que 36 chaves privadas em caminho operacional aparecem em mais de uma imagem. Se uma delas for usada em execução, todas as imagens dependem do mesmo segredo.

Só 4 módulos com primo compartilhado. Valeu o batch-GCD?

São 4 em 6.116 módulos, 0,065%. Abaixo dos 0,50% que Heninger achou em hosts TLS da Internet, e duas ordens de grandeza acima dos 0,00056% de chaves SSH de desenvolvedor. O teste acha só primo compartilhado: chave de baixa entropia que não colide fica de fora.

Qual a taxa de erro do extrator?

Fica em aberto, e digo isso de propósito. Nas 9.888 imagens em que o detector interno acha certificado, o CBOM-Lens relata na mediana metade, e supera o interno em 18% delas. Isso mostra cobertura diferente, não taxa de erro: não há verdade de referência, e inventar uma seria pior do que declarar em aberto.

O alcance do zero

O que os extratores leem, e o que não leem.

- Arquivo comum até 2 MB: DER, PEM, OpenSSH
- Lê biblioteca instalada por dpkg e apk
- Fora: estática, ofuscada, feita em execução

Os mesmos parsers leram 4.211.380 objetos.

O que conta como vulnerável

Nenhum objeto caiu na coluna pós-quântica.

Vulneráveis ao quântico

RSA

DSA

Diffie-Hellman

ECDSA e ECDH

Ed25519 e Ed448

X25519 e X448

Pós-quânticas

ML-KEM (Kyber)

ML-DSA (Dilithium)

SLH-DSA (SPHINCS+)

FN-DSA (Falcon)

FrodoKEM, HQC, BIKE

McEliece, XMSS, LMS

Por que o CSV diz 4.211.292

88 objetos que a coleta deixou sem rótulo.

- Chave pública X25519, fora do trust store
- X25519 é curva elíptica, e cai por Shor
- Corrigido no artefato; o CSV não foi regenerado

Nenhum dos 88 é pós-quântico. O zero fica.

De onde vêm os 4.211.380

Os quatro grupos, e a soma que fecha.

Certificados no trust store	3.511.725
Certificados fora do trust store	518.668
Chaves fora do trust store	178.455
Chaves no trust store	2.532
Total de chave pública	4.211.380

83% do total é bundle de trust store.

Por que separar o trust store

Sem o corte, o bundle compartilhado domina.

- **Entra: /etc/ssl/certs, /etc/pki e o certifi**
- **Duas chaves do apk: em 4.186 imagens cada**
- **Fora do trust store 43%, dentro 32,3%**
- **Caminho não diz quem criou nem quem usa**

Por que só a tag latest

O crawl enumera repositório, não lista de tags.

- latest é a única referência de todo repositório
- 34,7% não resolvem: existem, sem latest
- 193 de 200 reconferidas ainda existiam

As estimativas valem para latest baixável.

O que se perde nas 1.078

O limite de 4 GiB é escolha declarada.

- 657 passam de 4 GiB: são as imagens grandes
- A postura delas fica desconhecida
- 192 privadas e 148 sem variante amd64
- Das 81 que falharam, 46 são defeito nosso

Uma foto só, não uma série

O censo mede nível, não tendência.

- Não sabemos se o zero está subindo ou parado
- Mesma semente, mesma amostra: sorteio fixo
- Repetir em outra data vira série temporal

O quadro amostral está publicado para isso.